Relatório de Code Review

Projeto: /mnt/attach/project-files/codereview-local/exemplos/projeto-ruim

Data: 28/10/2026 10:32 · **Duração:** 2.4s

Linguagens: Python (1), C# (1)

19/100 conceito E (crítico)

Resumo por severidade

Severidade	Achados
Crítica	0
Alta	8
Média	8
Baixa	10
Info	2
Total	28

Skills executadas

Skill	Situação	Achados	Tempo	Observação
Segredos no código (Gitleaks)	Pulada	0	0.0s	gitleaks não encontrado (coloque gitleaks.exe em tools/).
Segurança multi-linguagem (Semgrep)	Executada	3	2.22s	
Segurança (Microsoft DevSkim)	Pulada	0	0.0s	devskim não encontrado (coloque devskim.exe em tools/).
Segurança Python (Bandit)	Executada	6	0.25s	
Dependências vulneráveis (OSV-Scanner)	Pulada	0	0.0s	osv-scanner não encontrado (coloque osv-scanner.exe em tools/).
Qualidade C# (Roslyn Analyzers)	Pulada	0	0.0s	.NET SDK não encontrado. Instale o SDK para habilitar esta skill.
Qualidade Python (Ruff)	Executada	7	0.02s	
Complexidade e tamanho de funções (Lizard)	Executada	2	0.01s	
Código duplicado (Lizard)	Executada	0	0.01s	

Skill	Situação	Achados	Tempo	Observação
Cobertura de testes (heurística)	Executada	1	0.0s	
Nomenclatura e padrões do time	Executada	9	0.05s	

Prioridades

#	Severidade	Local	Problema
1	Alta	-	Nenhum arquivo de teste encontrado para 2 arquivos de código.
2	Alta	`scripts/relatorio.py:7`	SQL montado com f-string/format/concatenação: risco de SQL injection.
3	Alta	`scripts/relatorio.py:8`	subprocess call with shell=True identified, security issue.
4	Alta	`scripts/relatorio.py:10`	Local variable `dados` is assigned to but never used
5	Alta	`scripts/relatorio.py:13`	Local variable `password` is assigned to but never used
6	Alta	`src/Api/PedidoService.cs:18`	SqlCommand com SQL montado por concatenação/interpolação: risco de SQL injection.
7	Alta	`src/Api/PedidoService.cs:19`	Bloco catch vazio engole exceções.
8	Alta	`src/Api/PedidoService.cs:25`	'async void' fora de event handler: 'async void Disparar('
9	Média	`scripts/relatorio.py:1`	`os` imported but unused
10	Média	`scripts/relatorio.py:1`	`sys` imported but unused

Achados por arquivo

Mensagens de ferramentas externas (Bandit, Ruff, Semgrep, Roslyn, OSV) são exibidas no idioma original.

(projeto) (1)

Linha	Seve.	Skill	Regra	Problema	Sugestão
-	Alta	testes	`sem-testes`	Nenhum arquivo de teste encontrado para 2 arquivos de código.	Crie um projeto de testes (xUnit/NUnit para C#, pytest para Python) começando pelas regras de negócio.

scripts/relatorio.py (14)

Linha	Seve.	Skill	Regra	Problema	Sugestão
1	Média	qualidade-python	`F401`	`os` imported but unused	Remove unused import
1	Média	qualidade-python	`F401`	`sys` imported but unused	Remove unused import
1	Baixa	seguranca-python	`B403 blacklist`	Consider possible security implications associated with pickle module.	https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_imports.html#b403-import-pickle
4	Baixa	qualidade-python	`N802`	Function name `gerarRelatorio` should be lowercase	https://docs.astral.sh/ruff/rules/invalid-function-name
7	Alta	seguranca-sast	`py-sql-fstring`	SQL montado com f-string/format/concatenação: risco de SQL injection.	CWE-89: SQL Injection (também: seguranca-python)
8	Alta	seguranca-python	`B602 subprocess_popen_with_shell_equals_true`	subprocess call with shell=True identified, security issue.	https://bandit.readthedocs.io/en/1.9.4/plugins/b602_subprocess_popen_with_shell_equals_true.html
9	Baixa	qualidade-python	`SIM105`	Use `contextlib.suppress(BaseException)` instead of `try`-`except`-`pass`	Replace `try`-`except`-`pass` with `with contextlib.suppress(BaseException): ...`
10	Alta	qualidade-python	`F841`	Local variable `dados` is assigned to but never used	Remove assignment to unused variable `dados`
10	Média	seguranca-python	`B301 blacklist`	Pickle and modules that wrap it can be unsafe when used to deserialize untrusted data, possible security issue.	https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b301-pickle
10	Baixa	qualidade-python	`SIM115`	Use a context manager for opening files	https://docs.astral.sh/ruff/rules/open-file-with-context-handler
11	Baixa	seguranca-python	`B110 try_except_pass`	Try, Except, Pass detected.	https://bandit.readthedocs.io/en/1.9.4/plugins/b110_try_except_pass.html
13	Alta	qualidade-python	`F841`	Local variable `password` is assigned to but never used	Remove assignment to unused variable `password`
13	Baixa	seguranca-python	`B105 hardcoded_password_string`	Possible hardcoded password: 'hunter2hunter2'	https://bandit.readthedocs.io/en/1.9.4/plugins/b105_hardcoded_password_string.html
14	Média	seguranca-python	`B307 blacklist`	Use of possibly insecure function - consider using safer ast.literal_eval.	https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b307-eval

src/Api/PedidoService.cs (13)

Linha	Seve.	Skill	Regra	Problema	Sugestão
8	Baixa	padroes	`cs-interface-sem-I`	Interface fora do padrão de nome: 'interface pedidoRepo'	Interfaces em C# devem começar com 'I' (ex.: IUserRepository).
15	Baixa	padroes	`cs-async-sem-sufixo`	Método assíncrono sem sufixo Async: 'async Task<int> Salvar('	Métodos que retornam Task devem terminar com 'Async'.
17	Info	padroes	`todo-fixme`	Pendência no código: // TODO: validar cliente	Transforme em tarefa no backlog ou resolva antes do merge.
18	Alta	seguranca-sast	`cs-sqlcommand-concatenado`	SqlCommand com SQL montado por concatenação/interpolação: risco de SQL injection.	CWE-89: SQL Injection (também: padroes)
19	Alta	padroes	`cs-catch-vazio`	Bloco catch vazio engole exceções.	Registre o erro (ILogger) ou relance com 'throw;'.
20	Baixa	padroes	`cs-console-writeline`	Console.WriteLine no código: use logging estruturado.	Injete ILogger<T> e use _logger.LogInformation(...).
21	Média	seguranca-sast	`cs-md5-sha1`	Algoritmo de hash fraco (MD5/SHA1).	CWE-327: Broken Crypto
22	Info	padroes	`cs-datetime-now`	DateTime.Now depende do fuso do servidor.	Prefira DateTime.UtcNow, DateTimeOffset ou TimeProvider (testável).
25	Alta	padroes	`cs-async-void`	'async void' fora de event handler: 'async void Disparar('	Retorne Task. Exceções em async void derrubam o processo e não podem ser aguardadas.
27	Média	complexidade	`complexidade-ciclomatica`	'PedidoService::Classificar' tem complexidade ciclomática 16 (limite 10).	Extraia métodos menores, use early return e substitua cadeias de if/switch por polimorfismo ou tabelas.
27	Baixa	complexidade	`muitos-parametros`	'PedidoService::Classificar' recebe 7 parâmetros (limite 6).	Agrupe os parâmetros em um objeto/record (Parameter Object).
34	Média	padroes	`cs-throw-ex`	'throw ex;' perde o stack trace original.	Use apenas 'throw;' para relançar.
35	Média	padroes	`cs-result-bloqueante`	Bloqueio síncrono de Task ('.Result') pode causar deadlock.	Use await em vez de .Result/.Wait().